

Proibida a reprodução e comercialização sem autorização

Usuário: Julio Cesar Justini dornellas, julio.justini@gmail.com, CPF: 05536778960

Ameaças (Vírus, Worms, Trojans, Malware, etc.)

Grande parte dos serviços que utilizamos no nosso dia a dia estão acessíveis por meio da Internet. Podemos, por exemplo, fazer uma transação financeira a partir do computador sem grandes problemas. Toda essa facilidade fez com que aumentasse o número de usuários da Internet e, também, o grau de dependência tecnológica da sociedade.

Entretanto, a Internet é uma rede pública, isto é, qualquer um pode estar nela. Assim, além da informação utilizada pelos usuários, existem ameaças que tentam aproveitar alguma brecha em sistemas para benefício próprio.

Essa "brecha" é conhecida pelo termo "**vulnerabilidade**". Dessa forma, vulnerabilidade é qualquer fragilidade, falha ou defeito presente em um sistema. Quando existe a possibilidade de uma determinada ameaça explorar vulnerabilidades que podem prejudicar uma organização, estamos diante de um **risco** de segurança da informação.

Apesar da Internet não ser a única fonte de ameaças, atualmente, é o local mais comum para a disseminação de softwares maliciosos (malwares).



Tome nota!

Conceitos importantes:

- Vulnerabilidade - qualquer fragilidade, falha ou defeito presente em um sistema.
- Ameaça - causa de um incidente indesejado, que pode resultar em dano para um sistema ou organização.
- Risco de Segurança da Informação - possibilidade de determinada ameaça explorar vulnerabilidades.

As principais ameaças cobradas em provas de concursos são:

Vírus: programas que se autorreplicam, alojam-se em outros programas ou arquivos, realizam ações não solicitadas, indesejadas e podem até destruir arquivos do sistema e corromper dados causando danos. Um vírus de computador tem um comportamento semelhante a um vírus de verdade (biológico), um programa "contaminado" pode infectar programas "saudáveis".

São acionados por um determinado evento que pode ser a execução do programa ou arquivo hospedeiro, alguma operação comandada pelo usuário ou até pela inicialização do computador.

Existe também alguns tipos de vírus:

- Vírus de **macro**: macros são "programas" que podem automatizar tarefas nos programas do Office. As macros podem ser criadas pelo próprio usuário. Um vírus de macro aproveita essa "liberdade" que o usuário tem de escrever sua própria macro para criar macros com o objetivo de danificar um documento, afetar o funcionamento do programa, etc.
- Vírus de **Boot**: o vírus de boot é um tipo de vírus que fica na área de inicialização de um disco rígido (HD). Essa área armazena qual é a formatação utilizada, o sistema de arquivos e outras informações. O grande problema desse tipo de vírus ficar nessa área é que ela é executada antes de qualquer programa, ou seja, antes mesmo

até do antivírus. Em razão disso, um vírus de boot tem, geralmente, um alto poder de destruição na máquina do usuário.



Questão quantíssima!

CESPE - Técnico Judiciário (TRT 10ª Região)/Administrativa/2013/

Arquivos anexados a mensagens de email podem conter vírus, que só contaminarão a máquina se o arquivo anexado for executado. Portanto, antes de se anexar um arquivo a uma mensagem para envio ou de se executar um arquivo que esteja anexado a uma mensagem recebida, é recomendável, como procedimento de segurança, executar um antivírus para identificar possíveis contaminações.

Comentário: o vírus é um programa e, portanto, precisa ser executado para que possa "agir" no computador. A execução do vírus pode ser realizada pelo próprio usuário (quando executa diretamente o vírus ou executa um outro programa que chama a execução do vírus) ou pela **exploração de vulnerabilidades em softwares** (que pode ser o sistema operacional ou um software aplicativo).

Ao explorar uma vulnerabilidade presente em um software, o vírus pode, por exemplo, ser configurado para ser executado junto com a inicialização do sistema operacional. Assim, o vírus precisa ser executado de alguma forma para contaminar o computador. Quando abrimos um e-mail pelo navegador (webmail) ou programa de correio eletrônico (Outlook, Thunderbird), existe um risco do computador ser contaminado por conta de uma vulnerabilidade.

Gabarito: **certo**.

Backdoors: normalmente um atacante procura garantir uma forma de retornar a um computador comprometido, sem precisar recorrer aos métodos utilizados na realização da invasão. Essa forma de retorno de um invasor a um computador comprometido dá-se o nome de backdoor. A forma usual de inclusão de um backdoor consiste na disponibilização de um novo serviço ou substituição de um determinado serviço por uma versão alterada, normalmente possuindo recursos que permitam acesso remoto (através da Internet). Assim, o backdoor pode ser visto como uma "porta" que o invasor abre para que possa retornar ao computador sem ser notado.

Cavalo de Tróia (trojan): programa que, primeiramente, aparenta ser inofensivo, mas que, num segundo momento, apresenta um comportamento malicioso. Por exemplo, você instala um jogo que, além de instalar o jogo, instala um software malicioso sem o seu conhecimento. Um trojan pode permitir que um atacante tenha controle sobre o computador por meio de recursos como backdoors.

Worm: programa malicioso que explora vulnerabilidades ou falhas de configuração nos softwares instalados para se propagar automaticamente através de redes, enviando cópias de si mesmo de computador para computador.



Tome nota!

A principal diferença entre um worm e um vírus é que o worm é capaz de se propagar automaticamente através da rede por meio de vulnerabilidades ou falhas de configuração nos softwares instalados.

Spyware (programa espião): tem o objetivo de monitorar atividades de um sistema e enviar as informações coletadas para terceiros. Pode ser utilizado de forma lícita por um administrador de rede, por exemplo, como de forma ilícita (capturar senhas de bancos, por exemplo). Alguns tipos de spyware são:

- **Keylogger:** capta as informações digitadas pelo usuário e as encaminha para terceiros.
- **Screenlogger:** o screenlogger é um programa parecido com o keylogger. A diferença é que aquele captura a tela do computador quando o usuário clica com o mouse.
- **Adware:** tipo de software especificamente projetado para apresentar propagandas, seja por meio de um browser, seja por meio de algum outro programa instalado em um computador.

Bot é um programa capaz de se propagar automaticamente, de modo similar ao worm, explorando vulnerabilidades existentes ou falhas na configuração de softwares instalados em um computador. Quando um computador é infectado por um bot, o invasor consegue controlá-lo remotamente e, assim, usá-lo para praticar ações maliciosas. O computador vira uma espécie de zumbi.

Quando o invasor consegue formar uma rede de mais de um computador infectado, temos uma rede de bots conhecida como "**botnet**". Quanto mais computadores conectados, maior poder o invasor tem e maior pode ser o dano que ele pode causar.

Ransomware: esse tipo de malware dá ao atacante a possibilidade de bloquear o computador remotamente por meio da Internet. Dessa forma, o computador é "sequestrado" e o usuário tem que pagar pelo resgate para voltar a utilizá-lo.

Ataques

Os ataques também exploram vulnerabilidades para que a ação seja bem sucedida. Dessa forma, uma simples falha na configuração de um programa, serviço ou equipamento de rede pode resultar em uma invasão de um sistema, no acesso a informações confidenciais, na indisponibilidade de um serviço, entre outras coisas.

Os ataques mais conhecidos são:

Força bruta - o atacante tem o objetivo de adivinhar um nome de usuário e senha por tentativa e erro. Normalmente é utilizado ferramentas automatizadas para isso, mas também pode ser realizado manualmente. O atacante pode coletar informações pessoais do usuário na Internet para aumentar suas chances de adivinhar o usuário e senha. Já que muitas pessoas costumam usar sobrenome, datas e números de documentos, por exemplo, como senha.

Negação de serviço (DoS) - o atacante envia diversas solicitações falsas para um site com o objetivo de esgotar os recursos computacionais. Dessa forma, o sistema fica sobrecarregado, acaba entrando em colapso e nega atendimento a todas as outras solicitações. Esse tipo de ataque pode ser pontecializado por meio de bonet (redes de computadores zumbis).

Sniffing (Interceptação de tráfego) - procedimento para analisar e monitorar o tráfego de uma rede realizado por um Sniffer (que pode ser software ou hardware). Pode ser utilizado por um administrador de rede para resolver alguns problemas, mas, também, pode ser utilizado para capturar arquivos, senhas e outros dados durante a transmissão dessas informações.

Defacement - o objetivo desse tipo de ataque é alterar a página de um site.

Alguns ataques utilizam a **Engenharia Social** que tem como principal ferramenta a persuasão para tentar obter informações sigilosas e, com isso, ter acesso a sistemas, computadores. Ou seja, a pessoa que aplica o golpe abusa da confiança ou ingenuidade do usuário para contornar dispositivos de segurança.

Atualmente, é comum pessoas colocarem muitas informações sobre sua vida em redes sociais (Facebook, Twitter). Isso acaba "ajudando" quem aplica esse tipo de golpe. Pois é possível enviar um e-mail muito específico para a vítima - despertando sua curiosidade.

Exemplos de golpes que utilizam a engenharia social:

Phishing é um tipo de fraude eletrônica projetada para roubar informações particulares que sejam valiosas para cometer um roubo ou fraude posteriormente. Por exemplo, o golpista envia um e-mail dizendo ser de um banco e induz o usuário a clicar em um link que leva a uma página falsa, que é semelhante ao do banco, para que seja digitada a senha da sua conta.

AFF (**A**dvan**ce** **F**ee **F**raud ou fraude de antecipação de pagamentos) é um tipo de golpe que utiliza a engenharia social para convencer as vítimas a realizarem um pagamento antecipado para que futuramente receba altas recompensas. O Golpe da Nigéria é um exemplo de AFF.

Pharming é um tipo específico de phishing que redireciona o usuário para sites falsos por meio de alterações no DNS (**D**omain **N**ame **S**ystem). Assim, mesmo que o usuário digite o endereço do site legítimo, o navegador pode ser redirecionado para uma página falsa (sem que o usuário perceba).

Hoax é uma mensagem falsa que é espalhada com o objetivo alarmar as pessoas. Ou seja, é um boato. O atacante pode usar esse tipo de boato, por exemplo, para espalhar códigos maliciosos.

Hacker e cracker

Os termos "Hacker" e "Cracker" servem para designar uma pessoa que possui muitos conhecimentos sobre a área de computação (softwares, programação, segurança, Internet, etc). A diferença entre esses dois termos está na forma como esse conhecimento é usado.

O **hacker** utiliza para o bem enquanto o cracker utiliza para o mal. Por exemplo, se um hacker descobrir uma vulnerabilidade em um sistema, então ele vai divulgar esse fato para que seja corrigido. Já o **cracker**, nesse mesma situação, tentaria tirar algum proveito disso (acessando dados sigilosos, violando a integridade do sistema, etc).



Tome nota!

Um **hacker** utiliza seus conhecimentos na área da computação de forma benéfica enquanto um **cracker** utiliza-os de forma maléfica (motivação destrutiva).

Resumo

► Conceitos importantes:

- **Vulnerabilidade** - qualquer fragilidade, falha ou defeito presente em um sistema.
- **Ameaça** - causa de um incidente indesejado, que pode resultar em dano para um sistema ou organização.
- **Risco** de Segurança da Informação - possibilidade de determinada ameaça explorar vulnerabilidades.

► Principais ameaças:

- **Vírus**: programas que se autorreplicam, alojam-se em outros programas ou arquivos, realizam ações não solicitadas, indesejadas e podem até destruir arquivos do sistema e corromper dados causando danos.
- **Backdoors**: normalmente um atacante procura garantir uma forma de retornar a um computador comprometido, sem precisar recorrer aos métodos utilizados na realização da invasão. Essa forma de retorno de um invasor a um computador comprometido dá-se o nome de backdoor.

- **Cavalo de Tróia** (trojan): programa que, primeiramente, aparenta ser inofensivo, mas que, num segundo momento, apresenta um comportamento malicioso.
- **Worm**: programa malicioso que explora vulnerabilidades ou falhas de configuração nos softwares instalados para se propagar automaticamente através de redes, enviando cópias de si mesmo de computador para computador.
- **Spyware** (programa espião): tem o objetivo de monitorar atividades de um sistema e enviar as informações coletadas para terceiros. Pode ser usado de forma lícita ou ilícita. Exemplos: keylogger, screenlogger e adware.
- **Bot** é um programa capaz se propagar automaticamente, de modo similar ao worm, explorando vulnerabilidades existentes ou falhas na configuração de softwares instalados em um computador. Quando um computador é infectado por um bot, o invasor consegue controlá-lo remotamente e, assim, usá-lo para praticar ações maliciosas. O computador vira uma espécie de zumbi. Esses computadores infectados forma uma rede chamada de **botnet**.
- **Ransomware**: esse tipo de malware dá ao atacante a possibilidade de bloquear o computador remotamente por meio da Internet. Dessa forma, o computador é "sequestrado" e o usuário tem que pagar pelo resgate para voltar a utilizá-lo.

► Principais ataques:

- **Força bruta** - o atacante tem o objetivo de adivinhar um nome de usuário e senha por tentativa e erro.
- **Negação de serviço** (DoS) - o atacante envia diversas solicitações falsas para um site com o objetivo de esgotar os recursos computacionais. Dessa forma, o sistema fica sobrecarregado, acaba entrando em colapso e nega atendimento a todas as outras solicitações.
- **Sniffing** (Interceptação de tráfego) - procedimento para analisar e monitorar o tráfego de uma rede realizado por um Sniffer (que pode ser software ou hardware). Pode ser utilizado de forma lícita ou ilícita.
- **Defacement** - o objetivo desse tipo de ataque é alterar a página de um site.

► Alguns ataques utilizam a **Engenharia Social** que tem como principal ferramenta a persuasão para tentar obter informações sigilosas e, com isso, ter acesso a sistemas, computadores. Exemplos:

- **Phishing** é um tipo de fraude eletrônica projetada para roubar informações particulares que sejam valiosas para cometer um roubo ou fraude posteriormente. A vítima normalmente é levada para uma página falsa.
- **AFF** (Advance Fee Fraud ou fraude de antecipação de pagamentos) é um tipo de golpe que utiliza a engenharia social para convencer as vítimas a realizarem um pagamento antecipado para que futuramente receba altas recompensas.
- **Pharming** é um tipo específico de phishing que redireciona o usuário para sites falsos por meio de alterações no **DNS** (Domain Name System).
- **Hoax** é uma mensagem falsa que é espalhada com o objetivo alarmar as pessoas.

► Um **hacker** utiliza seus conhecimentos na área da computação de forma benéfica enquanto um **cracker** utiliza-os de forma maléfica (motivação destrutiva).



Proibida a reprodução e comercialização sem autorização

Usuário: Julio Cesar Justini dornellas, julio.justini@gmail.com, CPF: 05536778960
